Risk Assessment and Evidence

Joseph Maguire

Enterprise Cyber Security

Overview

- What **risk** is, and why cyber risk covers both **malicious** and **non-malicious** threats.
- How **systems thinking** shows the parts that matter.
- The **ISO/IEC 27005** process: context, identification, analysis, evaluation and treatment, with monitoring and review.
- How **logs** become evidence for a likelihood, and where that evidence stops.
- What the **UK GDPR** asks of you, and how the assessment becomes a **policy**.

WHAT RISK IS

SYSTEMS

THE PROCESS

EVIDENCE

LAW AND POLICY

Where we left Aldermoor

November, and December

- The November logs show **credential stuffing**, **password spraying**, **brute force**, a **sudo** escalation, a **cron** persistence job, and outbound **transfers** of database size.
- In early December, Aldermoor's bank reports that cards used with Aldermoor are turning up in **fraud**.
- Today's question is not only "what happened?" It is "what should Aldermoor have assessed, and what should it do now?"

WHAT RISK IS

SYSTEMS

THE PROCESS

EVIDENCE

LAW AND POLICY

What risk is

Two definitions

Two sources, two wordings

Renn (2008), paraphrased

Human actions or events can lead to consequences that have an impact on what people value.

Refsdal, Solhaug and Stølen (2015)

“A risk is the likelihood of an incident and its consequence for an asset.”

Both point to three ideas: something can happen, it has consequences, and those consequences matter to someone.

Renn (2008), paraphrased. Refsdal, Solhaug and Stølen (2015), quoted.

Burnap (2026), CyBOK section 2, p. 3, cites Renn and Slovic for working definitions.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.
Renn, O. (2008) *Risk Governance: Coping with Uncertainty in a Complex World*. Routledge.
Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management*. Springer.
Slovic, P. (1987) Perception of risk. *Science*, 236(4799), pp. 280–285.

Risk in plain terms

The vocabulary

- Something going wrong that causes **harm or loss**.
- The thing that goes wrong is an **incident**.
- The **asset** is what has value to a **party**: a person, an enterprise or a body.
- **Likelihood**: the chance of the incident happening.
- **Consequence**: what the incident does to the asset. The assessment specification calls this **impact**.
- Likelihood and consequence together give the **risk level**.

A risk level is a judgement

Not a single number

- The levels come from a **matrix** of likelihood and consequence.
- Two careful assessors can rate the same risk differently.
- The job is to make the disagreement **visible**: name the evidence and the assumptions behind each rating.

Cyber risk: malicious and non-malicious

Aldermoor examples

Malicious	Non-malicious
A person or program intends harm.	An accident or an error.
Credential stuffing, password spraying, brute force, and the other attacks in the logs.	A `sudo` rule left too broad, a faulty update, or a backup that failed without anyone noticing.

Cyber risk is the **union** of the two. Some risks are both: a threat that uses an accidental weakness.

Cyberspace and cyber systems

Terms to use precisely

- **Cyberspace**: the complex environment of people, software and services on the Internet, and the networks and devices connected to it (ISO/IEC 27032). The Internet is an example, not the same thing.
- A **cyber system** depends on, or makes use of, cyberspace. That dependency can create **exposure** or **vulnerabilities**.
- **Cyber-physical systems** control and react to the physical environment, such as smart grids and autonomous vehicles.

ISO/IEC 27032:2023, terms and definitions (cyberspace). Cyber-physical systems: Burnap (2026), section 6.5, p. 25.

ISO/IEC 27032:2023 *Cybersecurity*. Geneva: ISO/IEC.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Cyber security and information security

Overlapping fields

- **Cyber security**: the defence of cyber systems from **cyber threats**. It is defined by the threat, not by the asset.
- **Information security**: the protection of information, from physical threats as well as cyber threats.
- Neither is a subset of the other. Standards often **conflate** them.

ISO/IEC 27000 (2018 edition, superseded in 2026); ISO/IEC 27032:2023 (cybersecurity).

ISO/IEC 27000:2018 *Information security management systems: Overview and vocabulary*. Geneva: ISO/IEC. Withdrawn; superseded by ISO/IEC 27000:2026.
ISO/IEC 27032:2023 *Cybersecurity*. Geneva: ISO/IEC.

The CIA triad
ISO/IEC 27000

- **Confidentiality**: information is not disclosed to unauthorised individuals, entities or processes.
- **Integrity**: the property of accuracy and completeness.
- **Availability**: accessible and usable on demand by an authorised entity.

Each property needs its own consequence scale, as the process section shows.

ISO/IEC 27000:2018 wording (confidentiality, integrity, availability). Superseded by ISO/IEC 27000:2026.
ISO/IEC 27000:2018 *Information security management systems: Overview and vocabulary*. Geneva: ISO/IEC. Withdrawn.
ISO/IEC 27000:2026 *Information security, cybersecurity and privacy protection: Information security management systems: Overview*. Geneva: ISO/IEC.

Critical infrastructure and safety

Beyond information security

- **Critical infrastructure**, such as energy, water, telecoms and emergency services, is crucial to modern life. Its protection goes beyond cyber security.
- **Safety** is freedom from unacceptable risk to human life, injury or damage (IEC 61508).
- Safety and security are distinct, but a cyber incident can affect safety.

Aldermoor's stock server also keeps the lifts monitored. A cyber incident there can become a safety issue.

IEC 61508 (2010), definition of safety. Directive (EU) 2022/2557 on critical entities (CER), which repealed Directive 2008/114/EC from 18 October 2024.

IEC 61508 (2010) *Functional safety of electrical/electronic/programmable electronic safety-related systems*, edition 2.0. Geneva: IEC.
Directive (EU) 2022/2557 on the resilience of critical entities. *Official Journal of the European Union*, L 333, 27 December 2022, pp. 164–198.

From perception to ranking

Three steps of judgement



Soft assumptions into hard judgements

The challenge

- Risk assessment is the process of turning **soft assumptions** into **hard judgements**.
- Balance **perceptions** against **actual evidence**.
- Start from what people believe, test it against evidence, then rank the risks you can defend.

Burnap (2026), CyBOK section 3, pp. 4–6, on perceived and actual risk, citing Slovic (1987).
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.
Slovic, P. (1987) Perception of risk. *Science*, 236(4799), pp. 280–285.

WHAT RISK IS

SYSTEMS

THE PROCESS

EVIDENCE

LAW AND POLICY

Systems thinking

Elements, interconnections, purpose

What a system is

- **Elements**: servers, databases, staff, contractors, backups, the bank, customers.
- **Interconnections**: how the parts affect each other. Aldermoor's contractor login, nightly backups, the ordering service and outbound connections.
- **Purpose**: what the system is for. It is hard to determine, and it should not be taken from what someone says or documents. Observe the system.

Meadows (2008) defines a system as a set of things, interconnected so that they produce their own pattern of behaviour over time.

Meadows (2008), Thinking in Systems: A Primer, paraphrased.

Meadows, D. H. (2008) *Thinking in Systems: A Primer*. Edited by D. Wright. White River Junction, VT: Chelsea Green.

Feedback, hierarchy and weak parts

Systems over time

- Behaviour that **persists over time** suggests a **feedback loop**. **Stabilising** loops resist change. **Reinforcing** loops grow, or collapse, in the direction of change.
- Systems are built from **hierarchies** of subsystems.
- An **insecure subsystem** does not form the basis of a strong system.
- At Aldermoor, the contractor's remote access is a subsystem of the stock server. A weak link there exposes the whole.

Meadows (2008), on feedback loops and hierarchies.

Meadows, D. H. (2008) *Thinking in Systems: A Primer*. Edited by D. Wright. White River Junction, VT: Chelsea Green.

Is the system failing?
Purpose decides

- People may call a system a failure when it succeeds for a different purpose.
- Perceived failure often comes from a **false expectation** of purpose.
- Systems adapt. **Workarounds** let people keep the purpose, even when a control gets in the way.
- Interfering with a system does not always give the outcome you want.

A control that slows staff invites a workaround. Plan for it.

Meadows (2008), on system purpose, feedback and resilience.
Meadows, D. H. (2008) *Thinking in Systems: A Primer*. Edited by D. Wright. White River Junction, VT: Chelsea Green.

Unintended consequences

Operation Cat Drop

- DDT was sprayed in Borneo homes against malaria mosquitoes. It reportedly poisoned cats, and rodent populations grew.
- In 1960, cats were parachuted into the Borneo highlands to hunt the rodents.
- Malaria control was assumed to mean mosquito control.
- In Brazil, control targeted the mosquito that fed on people. Cattle land went to grain, so the cattle-feeding mosquito may have switched to people.
- The problems persisted because the **system was not considered as a whole**. Look for the **links** before you change it.

O'Shaughnessy (2008). The Brazil account is a hypothesis, not a tested result.
O'Shaughnessy, P. T. (2008) Parachuting cats and crushed eggs: the controversy over the use of DDT to control malaria. *American Journal of Public Health*, 98(11), pp. 1940–1948. DOI: https://doi.org/10.2105/AJPH.2007.122523.
National Library Board, Singapore (1960) Press reports on the cat airdrop, Sarawak. NLB eResources.

What systems thinking gives the assessment

- **Decompose** the system into smaller chunks, then rebuild the picture.
- Name the **purpose** before you name the threats.
- Expect **hidden links**: a contractor's login can lead to a customer's card number.
- Human-intensive systems are **hard to decompose**. Say so, and state what you assumed.
- A countermeasure in one subsystem changes the wider hierarchy. Check its effect upwards.

WHAT RISK IS

SYSTEMS

THE PROCESS

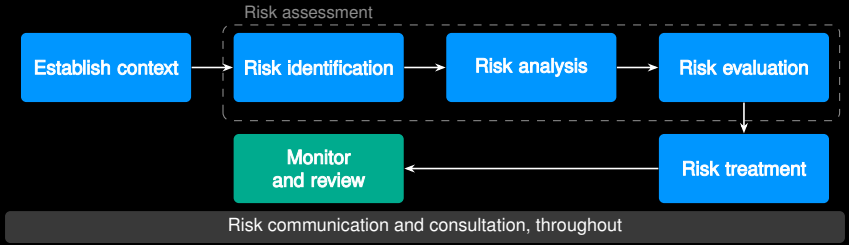
EVIDENCE

LAW AND POLICY

The risk process

The ISO/IEC 27005 process

Six stages, with communication throughout



Burnap (2026), CyBOK, Figure 6 and section 6.3, p. 19. Stage names follow ISO/IEC 27005:2022.

Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

The Refsdal cycle

Five stages, with ISO/IEC 27005 equivalents

Course stage	ISO/IEC 27005	Guiding question
Context	Establish context	What are the internal and external contexts, and the objectives? What is the target of the assessment?
Identification	Risk identification	What is the attack surface, and which threats and vulnerabilities use it?
Analysis	Risk analysis	What are the assets, the consequences and the likelihood?
Evaluation	Risk evaluation	Which risks matter most, against the criteria?
Treatment	Risk treatment	What would change the risk level most, before cost?

The five stages form a cycle. Communication runs throughout, and monitoring and review feed the next cycle.

Refsdal, Solhaug and Stølen (2015), the five-stage method. ISO/IEC 27005:2022 for the equivalent stages.

Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management.* Springer.
ISO/IEC 27005:2022 *Information security, cybersecurity and privacy protection: Guidance on managing information security risks.* Geneva: ISO/IEC.

What the standard asks for
ISO/IEC 27005

- It is less prescriptive than NIST guidance. Your analysis method sits inside the process.
- Assessment covers identification, analysis and evaluation. Treatment is part of risk management, linked to **communication** and **review**.
- Communication runs through the whole process. Monitoring and review close each cycle.
- Smaller organisations with less complexity can follow the principles in-house.

Burnap (2026), CyBOK, section 6.3, p. 19, and Table 1, p. 22. ISO/IEC 27005:2022 is the current edition.

Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.
ISO/IEC 27005:2022 *Information security, cybersecurity and privacy protection: Guidance on managing information security risks.* Geneva: ISO/IEC.

Stage 1
Context

What are the internal and external contexts, and the objectives? What is the target of the assessment?



Context

Stage 1

- **Internal and external context**: what shapes how Aldermoor manages risk. Staff, budget, the bank, the ICO, the contractor.
- **Objectives**: online orders, customer trust, and lawful processing of personal data.
- **Aims**: reduce the likelihood of undesirable incidents, and explain the assessment to people who know nothing about security.
- **Legal requirements**: the UK GDPR applies to customer data.
- **Risk criteria**: the level of risk the board will tolerate, and how levels are judged.

Scope and assumptions

Stage 1

- **Scope**: what you assess, and what you leave out, and say so. In scope: the stock server and the paths to it. Out of scope: the lift control systems themselves.
- **Focus**: the main thing being assessed.
- **Assumptions** about threat sources: for example, criminals have lists of leaked passwords, and a contractor's account can be stolen.
- Write them down. Someone else will need to check them.
- Elements you **control**, elements you **influence**, and elements you **do not control**: the contractor, the bank, the ICO.

Assets

Stage 1: what needs protecting

- Customer accounts and login details.
- Orders and payment details.
- Backups: the way back after a fault.
- Logs: the evidence of what happened.
- The ordering service: its **availability**.

For each asset, ask: what is the worst consequence to its **integrity**, **availability** and **confidentiality**?

Write each asset as a property to protect, such as “ensure order data stays protected from the web shop to the database”.

Attack surface

Stage 1: where the system meets cyberspace

- The contractor's **remote login** to the server, with a password.
- The **online ordering** service.
- **Outbound connections** from scheduled jobs.
- **Staff logins**, from the office and from home.
- **Physical** attacks nearby, such as tampering with a device on site.

The attack surface is what an attacker can reach or influence. Map it before you guess at threats.

Stage 2
Identification

What is the attack surface, and which threats and vulnerabilities use it?



The four core elements

Stage 2: vulnerability, threat, likelihood, impact

Element	Meaning	Aldermoor
Vulnerability	Open to attack or misuse, and could lead to an undesirable outcome	A password-only login for the contractor
Threat	An individual, event or action that can exploit a vulnerability	Credential stuffing by opportunistic criminals
Likelihood	The degree of possibility that the threat exploits the vulnerability	Frequent attempts in the November logs
Impact (consequence)	The negative effect on the objectives, if the threat succeeds	Customer records exposed, and a report to the ICO

Vulnerabilities are socio-technical: software, people and legal exposure all count.

Burnap (2026), CyBOK, section 6.2, pp. 15–16.
Definitions of vulnerability, threat, likelihood and impact.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Write a risk statement

Stage 2: cause, event, consequence

- **Cause**: the contractor's login accepts a password alone.
- **Event**: a stolen or guessed password opens a session on the stock server.
- **Consequence**: customer records leave the system, and the bank reports fraud.

A statement links the vulnerability, the threat and the outcome. "Cyber attack" on its own does not.

Burnap (2026), CyBOK, section 5.4, p. 12.
Risks are stated as links between vulnerabilities, threats, likelihoods and outcomes.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Two kinds of evidence

Stage 2: technical and non-technical

Technical

Logs, scans and tests. Lots of data, perhaps too much.

A test that finds nothing does not prove the vulnerability is absent.

Non-technical

Staff, stakeholders, standards, open repositories, news and research.

The challenge is relevance: does this evidence fit your system?

Identification comes from people as well as logs and tests. Set relevance criteria from the domain, the asset and the system type first.

Refsdal, Solhaug and Stølen (2015), on evidence for identification.
Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management.* Springer.

Identification: malicious threats

Stage 2: threat sources

Source	Motive	Capability
Opportunistic criminals	Money, from any account that works	Lists of leaked passwords, automation
Organised fraud groups	Card data to sell	Stolen credentials at scale, data transfers
Compromised third party	Access through a trusted contractor	Stolen contractor credentials, as at Target
Insider	A grudge, or personal gain	Sudo rights and knowledge of the system
Malware operator or campaign	The operator's aims, such as money or disruption	Malware: sophisticated, often built for off-the-shelf hardware and software

From source to incident

Stage 2: malicious chains

Source	Threat	Vulnerability	Incident	Asset
Opportunistic criminal	Credential stuffing	Password-only SSH login	Account taken over	Customer accounts
Fraud group	Password spraying	Guessable passwords	Repeated access	Orders and payment details
Compromised contractor	Use of valid contractor login	Password-only contractor access	Unauthorised data transfer	Customer and payment data

The chain runs from source to asset. Each link can be checked.

Non-malicious: work backwards

Stage 2: from the incident to the source

- Accidents have no attacker. Start from the **incident**, then find the **vulnerability**, the **threat** and the **source**. Read the table below from the incident back to the source.
- Human vulnerabilities are common: **training**, **workload**, stress and time pressure.
- Ask which **barriers** are missing, the ones that would have stopped the accident.
- Use logs, monitored data and history to find incidents that have already happened.

Refsdal, Solhaug and Stølen (2015), on working back from incidents.
Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management*. Springer.

Identification: non-malicious threats

Stage 2: accidents and errors

Source	Threat	Vulnerability	Incident
Maintenance staff	Errors during maintenance	Broad sudo rights, no review	A wrong change exposes the server
Software supplier	Faulty update	No staged testing on the server	Ordering service down
Backup process	Backup fails unnoticed	No check that backups restore	No way back after a fault

Stage 3
Analysis

What are the assets, the consequences and the likelihood?



Analysis: likelihood and consequence

Stage 3: quantitative or qualitative analysis

- How **likely** is the risk scenario or incident, given the threat and the vulnerability? Use attack repositories, logs and expert estimates.
- How **exploitable** or significant is the vulnerability? Consider how easy it is to exploit.
- What is the **consequence** for each asset?
- Estimate with **counts and probabilities**, or with **scenarios and labels**. Say which, and why.
- Justify each rating with a property of the system. Why is it rare, or why is it likely?
- Analyse malicious and non-malicious threats **separately**, then together.

An example scale

Worked example, with non-overlapping ranges

Likelihood	
Rare	under once in 20 years
Unlikely	once in 20 years to under once in 4 years
Possible	once in 4 years to under 4 times a year
Likely	4 to under 52 times a year
Certain	weekly or more

Consequence (availability)	
Insignificant	under 12 hours
Minor	12 to under 24 hours
Adequate	24 hours to under 3 days
Significant	3 to under 7 days
Critical	7 days or more

Refsdal, Solhaug and Stølen (2015), worked example, with boundaries adjusted so that levels do not overlap.
The units belong to that example.

Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management.* Springer.

Each property gets its own scale

Same levels, different units

Level	Integrity: customers affected	Availability: time offline
Insignificant	Under 50 customers	Under 12 hours
Minor	50 to 199 customers	12 to under 24 hours
Adequate	200 to 499 customers	24 hours to under 3 days
Significant	500 to 1,999 customers	3 to under 7 days
Critical	2,000 or more customers	7 days or more

The labels are shared. The units differ, because integrity and availability harm different things.

Refsdal, Solhaug and Stølen (2015), worked example, integrity and availability scales, with boundaries adjusted so that levels do not overlap.
The units belong to that example.
Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management.* Springer.

Build the scale from the asset

Stage 3: units you can count

- Customer accounts: **people** affected, records exposed.
- Payment details: **cards** exposed, fraud losses, a report to the ICO.
- Ordering service: **hours** offline, orders lost.
- Backups: time since the last **good** copy.

A scale has a unit. Its levels do not overlap. Its top level is the worst **credible** case.

Strengthen your scales

Stage 3: relevant external sources

- **Strengthen** each scale with relevant external sources. Use published frameworks, regulatory guidance, or data on what comparable incidents have cost, to justify each level.
- Kinds of evidence: your **logs**, **academic literature**, **peer-reviewed research**, **state guidance**, **regulators** and **news reporting of real incidents**.
- Cite at least **four** external sources across the assessment, including one **peer-reviewed** source.
- For every rating, say whether it rests on your **logs**, on an **external source**, or on **both**.

Group assessment specification, Part 2, Step 2.
Examples of named sources follow on the next slide.

Sources to start from

Sources you can transfer to your own system

- **Account takeover**: stolen passwords used against online accounts.
- **Card data**: remote access that could reach it.
- **Breach cost**: what a card-data breach has cost in fines.
- **Remote access**: multi-factor authentication as the main control.

Group assessment specification, Part 2, Step 2. Named sources for the evidence.

Thomas, K. et al. (2017) Data breaches, phishing, or malware? Understanding the risks of stolen credentials. In: *Proceedings of the ACM Conference on Computer and Communications Security (CCS 2017)*. New York: ACM.

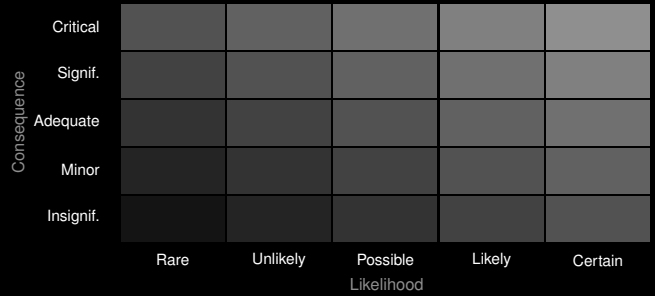
PCI Security Standards Council (2024) *Payment Card Industry Data Security Standard (PCI DSS)*, version 4.0.1, requirement 8.4.3. Available at: https://www.pcisecuritystandards.org/document_library/.

Information Commissioner's Office (2020) *Penalty notice: British Airways plc*, case ref. COM0783542, 16 October 2020. Available at: https://ico.org.uk/media/action-weve-taken/mpns/2618421/ba-penalty-20201016.pdf.

National Cyber Security Centre (2018) *Password policy: updating your approach*. Reviewed 19 November 2018. Available at: https://www.ncsc.gov.uk/collection/passwords/updating-your-approach.

The risk matrix

Stage 3: likelihood by consequence



Place each risk on the grid, using the scales you built.

The matrix can mislead

Stage 3: read the grid with care

- Combining likelihood and consequence into one grid has known **limits**.
- Two risks in one cell can differ a lot in their consequences.
- Ask what the picture is for, and whether the evidence behind it is accurate.
- Keep the scales and the evidence beside the grid.

Cox (2008), “What’s wrong with risk matrices?” *Risk Analysis*, 28, pp. 497–512.
Also cited in Burnap (2026), CyBOK, section 5.4, p. 12.
Cox, L. A. (2008) What’s wrong with risk matrices? *Risk Analysis*, 28, pp. 497–512.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Stage 4
Evaluation

Which risks matter most, against the criteria?



Evaluation

Stage 4

- Compare each level with the **objectives** and with what the organisation will **accept**.
- **Rank** the risks. The aim is the most important risks, not every risk anyone can name.
- Estimate the effect of each treatment on the level **before** you consider its cost.

Evaluation gives one of three outcomes

Stage 4: compare each risk with the criteria

Outcome	What the evaluation decides	Aldermoor
Intolerable	Abandon or replace the activity. If that is not possible, reduce the vulnerability and limit the exposure.	The password-only contractor login
Tolerable	Reduce the risk by reasonable means, as low as reasonably practicable (ALARP) or allowable (ALARA).	Backups that fail without notice
Acceptable	No further reduction is needed. Proceed, and review. Risk can also be taken to pursue an opportunity.	A short ordering outage at night, recorded

Burnap (2026), CyBOK, section 3, pp. 4–5, for the three outcomes. ALARP and ALARA: glossary, p. 36.

Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Stage 5
Treatment

What would change the risk level most, before cost?



Treatment

Stage 5: four options

- **Avoid**: stop the activity, or remove the asset. For example, end the password-only contractor login.
- **Reduce**: add or change controls. For example, key-based access with a time limit, and logs forwarded to a second store.
- **Transfer**: move part of the risk, by contract or insurance. Accountability under the UK GDPR stays with the controller.
- **Accept**: record the decision, its owner and when it will be reviewed.

One treatment can address several risks, so **group** them, by vulnerability, source or threat. Every control also has **side effects** on the wider system.

Prioritise the fixes

Stage 5: vulnerability management

- Vendors release patches regularly. Plan to apply them on a **schedule**.
- Rank by the **impact** of an exploit on the rest of the system.
- Rank by **visibility**: an Internet-facing service is an open target.
- Rank by **ease**: can an automated exploit reach it?
- Active scans can disrupt legacy and operational devices. Scan them with care.

At Aldermoor, the contractor's SSH path comes first: external logins succeeded on it. The ordering service comes next. An unmade fix needs a reason and the risk owner's approval.

Burnap (2026), CyBOK, sections 6.4 and 6.5, pp. 25–26.
Vulnerability management, scanning and cyber-physical systems.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Show the treatment works

Stage 5: metrics and a plan

- A **metric** is something you can count before and after. For example: successful contractor logins outside agreed hours, per week.
- Good metrics are **consistent**, cheap to collect, a number with a unit, and useful for a decision.
- An **implementation plan** says who does what, by when, and how you will know it is done.
- Example: week 1, change the contractor's access. Week 2, review the logs for the same measure.

Accept only with an owner

Stage 5: risk acceptance

- Acceptance records that the **residual risk** is tolerable.
- Each accepted risk has a named **owner**, with oversight of the asset.
- Each accepted risk has a **review date**, tied to the review process.
- If the risk is not accepted, return to **treatment**.

Burnap (2026), CyBOK, section 5.4, p. 13, on accepted risks and their owners.

Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Communicate throughout

Risk communication and consultation

- **Education**: awareness of risk, and of its day-to-day handling.
- **Training**: turn awareness into changed practice.
- **Confidence**: trust, built over time through strong performance.
- **Involvement**: stakeholders take part in decisions and in resolving conflict.
- **Leading by example**: staff resent rules that managers do not follow.

A board needs different information from operational staff. Tailor the message.

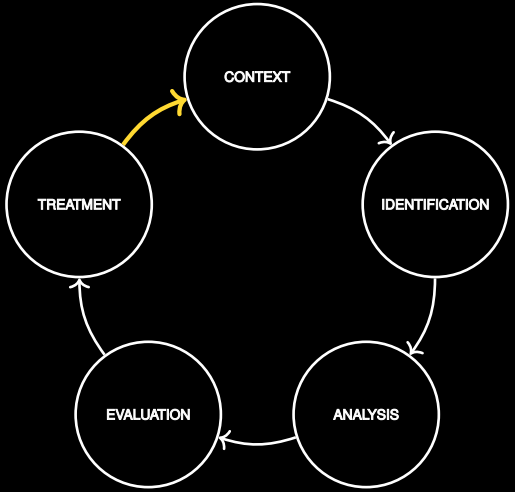
Burnap (2026), CyBOK, section 5.2, p. 10.
Education, training, confidence, involvement and leading by example.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Monitor and review

A process, not a product

- A **tick-box** assessment gives a false sense of security.
- Watch the **risk factors**: new devices, new suppliers, new ways of working.
- After each change, revisit the **scope**, the **purpose** and the **assumptions**.
- An annual compliance review leaves gaps between its dates.
- Report each new risk found to the stakeholders who must act on it.

Burnap (2026), CyBOK, section 3, pp. 7–8 (tick-box assessment), and section 6.3, p. 18 (risk factors and review).
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.



Once the risk is treated, the cycle begins again.

Each stage hands on to the next. Treatment is not the end, because the treated risk is assessed again from context.

“Security is a process, not a product.” Bruce Schneier.

Schneier (2000), Computer Security: Will We Ever Learn? *Crypto-Gram*, 15 May.
Schneier, B. (2000) Computer Security: Will We Ever Learn? *Crypto-Gram*, 15 May. Available at: https://www.schneier.com/crypto-gram/archives/2000/0515.html.

WHAT RISK IS

SYSTEMS

THE PROCESS

EVIDENCE

LAW AND POLICY

Evidence and risk

Logs give likelihood

Frequency and pattern

- **Counts** give frequency: attempts per day or per week.
- **Patterns** identify the threat. **Credential stuffing**: stolen username and password pairs tried against accounts, often with few attempts per account. **Password spraying**: one or a few passwords across many accounts. **Brute force**: many password guesses.
- A spread of source addresses is a log **signature** only. It does not define the attack.
- A **baseline** says what normal looks like: office logins on weekdays, `sudo` for maintenance.
- State your **rules and thresholds**, so someone else can check them.

Logs do not give consequence

A count is not a consequence

- “142 failed logins” is **evidence**: a count.
- Outbound transfers of database size every night since 19 November are **evidence of exfiltration**. The logs show their size, which matched the database, not its contents.
- A **breach** is the outcome: customer records were taken. Other evidence must show it.
- **Consequences** come after that: customers affected, cards exposed, fines and a report to the regulator.

How far can the logs be trusted?

Evidence weaknesses

- Lines sent with a single `@` over UDP can be **lost, read or forged** on the way.
- Root can **alter local logs**.
- An older format has **no year, time zone or origin**, so events are hard to order and date.
- Any local user can write a line that **claims to be** `sshd`.

A likelihood built on these logs has **wider uncertainty**. Say so, and give a range.

Assumptions and unknowns

Write them down

- The **year and time zone** were assumed: 2026, and UTC.
- A new service on 21 November, `update-helper.service`, is not linked to the attacker. Record it as **unexplained**.
- Which passwords were tried is **inferred** from patterns, not seen.

An unknown that is listed is safer than an unknown that is hidden.

Evidence is not the whole picture

Concern assessment

- People rank **dread** risks, such as nuclear accidents, as the highest risk. Domain experts rank them much lower.
- People downplay common risks, such as street crime and accidents at home, which kill far more people.
- **Concern assessment** captures what stakeholders fear, and why. It covers control, trust and familiarity.
- Assess concern alongside the evidence. Otherwise the plan may be rejected.

Burnap (2026), CyBOK, section 3, pp. 4–6, citing Slovic (1987).
Concern assessment and perceived risk.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.
Slovic, P. (1987) Perception of risk. *Science*, 236(4799), pp. 280–285.

WHAT RISK IS

SYSTEMS

THE PROCESS

EVIDENCE

LAW AND POLICY

Law and policy

The UK GDPR asks for risk judgements

Articles 32, 33 and 35

- **Article 32**: security **appropriate to the risk**, taking into account likelihood and severity for people's rights and freedoms.
- **Article 33**: a personal data breach likely to result in a risk to people's rights and freedoms is reported to the **Information Commission (ICO)**, where feasible within **72 hours**.
- **Article 35**: a data protection impact assessment is needed where processing is likely to result in a **high risk**.

UK GDPR (Regulation (EU) 2016/679, as amended), Articles 32, 33 and 35.
Regulation (EU) 2016/679 (General Data Protection Regulation), as amended in UK law (UK GDPR), Articles 32, 33 and 35. Available at: https://www.legislation.gov.uk/eur/2016/679/contents.
https://www.legislation.gov.uk/eur/2016/679/article/32 https://www.legislation.gov.uk/eur/2016/679/article/33 https://www.legislation.gov.uk/eur/2016/679/article/35

Your assessment is key evidence

Appropriate to the risk

- A **documented risk assessment** is key evidence supporting why the organisation considered its security appropriate.
- An undocumented judgement is **hard to defend**, even if it was correct.
- Keep the stages, the scales, the evidence and the decisions.

From assessment to policy

What a policy says

- **Who** may access what, and **how**.
- How logs are **kept, reviewed and protected**.
- Who decides whether to **accept** a risk, and how often the decision is reviewed.

A policy is short and checkable. Each rule should trace back to a risk in your assessment.

Your group assessment

Evidence-based Policy Group Assessment

1. Context, objectives, scope and assumptions.
2. Assets and the attack surface.
3. Malicious and non-malicious threats, incidents and vulnerabilities.
4. Likelihood and consequence scales that your group designs from its assets.
5. Evaluation and treatment.
6. Metrics and an implementation plan.
7. A one-page policy, tied to your evidence.

Summary

- Risk is the **likelihood** of an incident and its **consequence** for an asset. Cyber risk is malicious, non-malicious, or both.
- Systems thinking: find the **elements**, **interconnections** and **purpose**, and the hidden links.
- The ISO process shown here has six stages; the course groups these into five, from **context** to **treatment**. Scales come from your assets.
- Logs give **frequency** and **pattern**. They do not give consequence on their own, and they have limits.
- The UK GDPR asks for appropriate security. A **documented risk assessment** is key evidence supporting that judgement.

Further reading

Read these after the lecture

Book

Cyber-Risk Management by Refsdal, Solhaug and Stølen (2015) is a book-length treatment of cyber-risk management. Read it for the method in more depth, and for examples beyond these slides.

CyBOK

The **Risk Management & Governance** knowledge area. Read sections **2** and **3** for definitions and assessment, **5.4** for risk statements, and **6.3** for the ISO/IEC 27005 process.

Refsdal, Solhaug and Stølen (2015), *Cyber-Risk Management*. Burnap (2026), CyBOK, Risk Management & Governance.
Refsdal, A., Solhaug, B. and Stølen, K. (2015) *Cyber-Risk Management*. Springer.
Burnap, P. (2026) Risk Management & Governance Knowledge Area, version 1.1.2. In: *The Cyber Security Body of Knowledge (CyBOK)*, ed. A. Rashid. National Cyber Security Centre. Available at: https://www.cybok.org/.

Risk Assessment and Evidence

Joseph Maguire

Enterprise Cyber Security